

What is OWASP ZAP

(Open.Web.Application.Security.Project.Zed.Attack.Proxy)

- A free, open-source web application security scanning tool.
- Created by OWASP
(Open Web Application Security Project).
- Helps find vulnerabilities in websites and APIs.
- Used by beginners, students, and professional penetration testers.

What Does OWASP ZAP Do?

- Scans websites for security weaknesses.
- Identifies common vulnerabilities like XSS, SQLi, CSRF, Path Traversal, etc.
- Captures and analyzes all traffic between browser and server (proxy).
- Automatically attacks target websites (active scanning).
- Helps test security during development or penetration testing.

★ Why Do We Use OWASP ZAP?

- It is 100% free and beginner-friendly.
- Supports automation, scripting, and CI/CD pipelines.
- Gives detailed reports about vulnerabilities.
- Detects issues early before real attackers exploit them.
- Helps developers and security testers improve website security.



Most Important Features of OWASP ZAP

- 🔍 1. Passive Scan
- ⚡ 2. Active Scan
- 🌐 3. Intercepting Proxy
- 🧪 4. Fuzzer
- 🔄 5. Spider / Crawler
- 😬😞 6. Authentication Testing
- 📊 7. Reporting
- 🧩 8. Add-ons Marketplace

How OWASP ZAP Works?

- Works as a proxy between your browser and website.
- You configure your browser to pass traffic through ZAP.
- ZAP captures all requests/responses.
- Then ZAP: Performs passive scan, Performs active scan,
Runs crawlers, Sends attack payloads, Detects
vulnerabilities
- Finally, ZAP generates a detailed security report.